PRIAM: a Metamodel for Privacy-by-Design Software Engineering (Evaluation part)

No Author Given

No Institute Given

1 Questionnaire Design

To set up our questionnaire, we decided to use a questionnaire designed and tested by experts in the field. After a review of the literature, we identified several relevant questionnaires [1,3,5,6,9]. In order to choose the most appropriate one in terms of completeness and coverage of the GDPR, we carried out two types of evaluations, a qualitative and a quantitative one. These are presented below.

A. Selection of Questions We performed the qualitative evaluation ourselves manually. The second evaluation is a quantitative one, using natural language processing techniques, and is based on the calculation of similarity. This second evaluation is performed in order to confirm the results of the first evaluation. By combining these two evaluations, we can make an informed decision on which questionnaire to use for our study.

A.1. Qualitative Assessment In this section we present the results of our qualitative evaluation. To do this, we reviewed each of the questionnaires. We found that the questions were grouped into categories. The number of categories and questions differed from one questionnaire to another. Therefore, we cannot consider the predefined categories as a comparison criterion. So, we did a second reading and concluded that the best way to compare them was to see which aspects of the GDPR the questionnaires covered. We analyzed the questions one by one. Given the large number of aspects and in order to reduce the complexity of the comparison table, we grouped them as follows:

- Lawfulness: consent, decisions for minors, legal basis, record of processing activities;
- User rights: to be informed, withdrawal of consent, access, portability, erasure, rectification, restriction, objection, automated decision making and profiling;
- Accountability and governance: purpose, accuracy, minimization, data retention, third parties, DPO, DPIA and control representatives;
- Security and Breaches;
- Transferability: data transfer outside the EU.

These groups thus form our comparison criteria for the qualitative analysis, based on observation and intuition. Each group of the list represents one "*GDPR aspect*", and it is composed of several "*sub-aspects*" that are listed exhaustively above. We added

to the list of criteria the clarity of questions. By clarity we mean whether the question makes it possible to know which concept is being addressed without having to refer to its explanations. We also added to these criteria the number of questions by questionnaire, which gives an indication on the level of detail of the questionnaire. qualitative evaluation shows our results. The indicated score, in terms of number of bullets, is a ratio of the number of sub-aspects of the GDPR aspect of the column in the table which are addressed by the questions of the questionnaire, to the total number of sub-aspects of that GDPR aspect. For instance, in Questionnaire [1], on the "*User rights*" aspect, there are approximately 80% of sub-aspects (4 bullets out of 5) that are covered by the questions of this questionnaire.

Table 1: Qualitative assessment of questionnaire

			GDPR Aspects				
Ref	Number of questions	Clarity of questions	Lawfulness	User rights	Accountability & Governance	Security & Breaches	Transfer outside EU
[6]	54	●●●●●	●●●●○	●●●●●	●●●●●	●●●●●	●●●●●
[1]	31	●●○○○	●●●●●	●●●●○	●●◐○○	●●●●●	●●●●●
[9]	31	●●●●●	●●●●○	●●○○○	●●◐○○	●●◐○○	○○○○○
[5]	19	●●○○○	●●●●○	●●●●○	●●●○○	●●●●●	●●●●●
[3]	32	●●●●○	●●●●○	●●●●○	●●●○○	●●●●●	●●●●●

From the results of this table, we can observe that Questionnaire [6] has the highest score in all columns. It is the one that processed the most aspects of GDPR.

A.2. Quantitative Assessment In order to confirm the results obtained previously, we proceeded to a second automatic evaluation based on the NLP. We compared each of the questionnaires to a set of key terms from the GDPR. To do this, we used the French-English data protection glossary of the official website of the CNIL [2], which contains 430 lines, as well as the titles of the 99 articles of the regulation [4]. We consider that these two sources are very representative and include the key terms of the GDPR.

A second study was conducted to compare the questionnaires to the full text of regulation. We used NLP techniques to measure the similarity between the questionnaires and the GDPR documents (key terms and full text). The process we followed is presented in questionnaire.

Data Collection. The goal of this step is to record each questionnaire and the GDPR terms/expressions in separate text files. The questionnaires [1,3,5,6], the French-English data protection glossary [1] and the titles of the GDPR articles [2] are available online. For the questionnaire [9], we accessed the GitHub repository of the application proposed by [3] to extract the questionnaire.

[1] https://www.cnil.fr/en/english-french-glossary-data-protection
[2] https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32016R0679
[3] https://github.com/ElsevierSoftwareX/SOFTX-D-20-00011

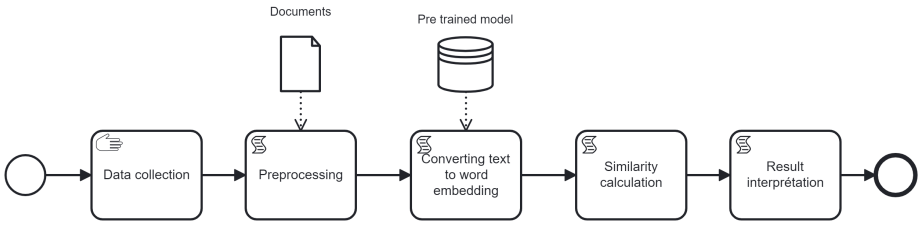

Fig. 1: NLP-based similarity calculation process

Preprocessing. This step consists of transforming the text from its "raw" form to a more suitable form that the machine can process. This step is very important because the quality of the data can impact the results. The pre-processing step is a process in itself composed of several operations, like tokenization, removal of stop words and lemmatization.

Vectorisation of Words. Once the documents have been pre-processed, they have been converted into numerical vectors that allow us to calculate the similarities between the questionnaires and the "GDPR key terms" document. There are different approaches including, TF-IDF or Word Embeddings. The method that gave us the best results is the second in which we used two pre-trained models: Word2vec [8] from Google and FastText [7] from Facebook AI. At the end of this step, we obtained the vector representations (embeddings) of each document (the average of the word vectors).

Similarity calculation. This step consists in measuring the similarity between the questionnaires and the "RGPD key terms" document once their vectors have been calculated. We used the cosine similarity, the Euclidean distance and the Manhattan distance available on Python libraries.

Result Interpretation. We present in comparaison table (at the left-hand side) the results of the comparison of similarities [10] (cosine (Cos), Eucledean (Euc) , Manhattan (Man)) between the 5 questionnaires and the document "RGPD key terms", using two word embedding models (Google's word2vec and fastText's Common cowl) and two lemmatization techniques (WordNet and Spacy Lib).

The two word embedding models are presented in columns, while the two lemmatization techniques are presented in rows. The results of the similarity measures per questionnaire, for each combination of word embedding and lemmatization, are presented in the cells.

Cells with bold text contain the highest similarity values. The results in comparaison table show that questionnaire [6] has the highest similarity to the "GDPR key terms" document followed by [3] on all three similarity measures, regardless of the used word embedding model and lemmatization technique.

To confirm these results, we performed a second analysis that consists of calculating the similarity between the questionnaires and the full text of the regulation. These results are presented in comparaison table (at the right-hand side).

Table 2: comparaison tables

		Keys terms						Full text					
		Google news			FastText			Google news			FastText		
Type of lemme		Cos	Euc	Man	Cos	Euc	Man	Cos	Euc	Man	Cos	Euc	Man
WordNet (NLTK lib)	[6]	**0.917**	**0.644**	**-3.823**	**0.924**	**0.88**	**-0.49**	**0.947**	**0.72**	**-2.88**	**0.927**	**0.883**	**-0.533**
	[1]	0.887	0.579	-4.692	0.866	0.839	-1.128	0.921	0.651	-3.951	0.866	0.838	-1.128
	[9]	0.866	0.523	-5.49	0.838	0.812	-1.586	0.886	0.559	-4.951	0.839	0.812	-1.59
	[5]	0.887	0.571	-4.811	0.876	0.831	-1.339	0.884	0.57	-4.97	0.865	0.825	-1.387
	[3]	0.902	0.607	-4.519	0.898	0.863	-0.844	0.925	0.66	-3.514	0.884	0.853	-0.903
Spacy lib	[6]	**0.924**	**0.647**	**-3.833**	**0.933**	**0.882**	**-0.532**	**0.939**	**0.685**	**-3.409**	**0.897**	**0.853**	**-0.948**
	[1]	0.902	0.592	-4.589	0.881	0.841	-1.113	0.915	0.618	-4.292	0.837	0.811	-1.463
	[9]	0.879	0.531	-5.369	0.85	0.806	-1.677	0.885	0.541	-5.277	0.814	0.785	-1.953
	[5]	0.903	0.587	-4.635	0.892	0.837	-1.278	0.888	0.56	-5.149	0.854	0.813	-1.525
	[3]	0.914	0.617	-4.416	0.912	0.864	-0.875	0.92	0.629	-4.078	0.859	0.827	-1.246

By comparing the results of the two tables, we can conclude that [6] is the questionnaire that is the closest to the GDPR; it covers the most provisions, compared to the other questionnaires. This is the questionnaire that was selected for conducting the interviews.

References

1. Controllers checklistlico [online]. available at. `https://ico.org.uk/for-organisations/sme-web-hub/checklists/data-protection-self-assessment/controllers-checklist/`. (Accessed on 03/01/2023).
2. English-french glossary on data protection | cnil. `https://www.cnil.fr/en/english-french-glossary-data-protection`. (Accessed on 03/01/2023).
3. Eu gdpr readiness assessment tool [online]. available at. `https://advisera.com/tools/eu-gdpr-readiness-assessment-tool/`. (Accessed on 03/01/2023).
4. Gdpr archives - gdpr.eu. `https://gdpr.eu/tag/gdpr/`. (Accessed on 03/01/2023).
5. Gdpr checklist for data controllers [online]. available at. `https://gdpr.eu/checklist/`. (Accessed on 03/01/2023).
6. Preparing your organisation for the general data protection regulation - your readiness checklist [online]. available at. `https://www.dataprotection.ie/sites/default/files/uploads/2019-04/A-Guide-to-help-SMEs-Prepare-for-the-GDPR.pdf`. (Accessed on 03/01/2023).
7. Piotr Bojanowski, Edouard Grave, Armand Joulin, and Tomas Mikolov. Enriching word vectors with subword information. *Transactions of the association for computational linguistics*, 5:135–146, 2017.
8. Tomas Mikolov, Kai Chen, Greg Corrado, and Jeffrey Dean. Efficient estimation of word representations in vector space. *arXiv preprint arXiv:1301.3781*, 2013.
9. Fábio Pereira, Paul Crocker, and Valderi RQ Leithardt. Padres: Tool for privacy, data regulation and security. *SoftwareX*, 17:100895, 2022.
10. Jiapeng Wang and Yihong Dong. Measurement of text similarity: a survey. *Information*, 11(9):421, 2020.